

Guía de Laboratorio DFIR: Adquisición de Memoria y Análisis Avanzado de Malware

FASE 1: Adquisición en la Escena del Incidente (Live Forensics)

Entorno: Máquina Virtual Metasploitable 3 (Víctima)

Objetivo: Extraer la memoria RAM volátil hacia un medio externo, asegurando su integridad matemática (Hashing) y aislando el sistema.

Paso 1: Conexión del Medio Estéril (Pendrive Forense)

Explicación para la clase: Al llegar a un servidor comprometido que está encendido, el perito **nunca** apaga el equipo inmediatamente (se perdería la RAM). En su lugar, conecta un disco duro externo o pendrive forense. Linux no asigna una letra (como C: o D:) automáticamente, por lo que debemos "montar" el dispositivo manualmente.

```
sudo mkdir -p /mnt/pendrive_forense  
sudo mount /dev/sdb1 /mnt/pendrive_forense
```

Desglose técnico de los comandos:

- **sudo:** Invoca privilegios de superusuario (root), necesarios para interactuar con el hardware a bajo nivel.
- **mkdir -p:** Crea un directorio (make directory). El flag -p asegura que no devuelva error si la carpeta ya existe.
- **/mnt/pendrive_forense:** Es el "Punto de Montaje", una carpeta vacía que servirá como puerta de acceso a nuestro pendrive.
- **mount:** Comando que le dice al kernel que conecte el hardware al sistema de archivos.
- **/dev/sdb1:** Es la ubicación física. /dev (devices), sd (SCSI/SATA drive), b (el segundo disco, siendo 'a' el disco principal), 1 (la primera partición de ese disco).

Paso 2: Ejecución del Volcado Directo (Live RAM Dump)

Explicación para la clase: Vamos a utilizar **AVML** (Acquire Volatile Memory for Linux). A diferencia de copiar archivos normales, copiar la RAM implica leer estructuras dinámicas del kernel (/dev/mem o /proc/kcore) sin provocar que el servidor se congele (Kernel Panic).

```
wget https://github.com/microsoft/avml/releases/download/v0.13.0/avml
chmod +x avml
sudo ./avml /mnt/pendrive_forense/CASO_003_RAM.raw
```

Desglose técnico de los comandos:

- `chmod +x`: Cambia los permisos del archivo descargado para volverlo ejecutable (+x, execute).
- `./avml`: Ejecuta la herramienta.
- `/mnt/pendrive_forense/CASO_003_RAM.raw`: **(Concepto Crítico)** Le indicamos a la herramienta que el archivo resultante (el volcado) se escriba **directamente en el pendrive**.
 - *Nota al alumno:* Si guardáramos este archivo de 2GB en el disco duro de la víctima (ej. en /tmp), destruiríamos 2GB de espacio libre (espacio no asignado), eliminando para siempre posibles archivos borrados por el atacante que podríamos recuperar más adelante mediante File Carving.

Paso 3: Sellado de la Evidencia (Cadena de Custodia)

Explicación para la clase: Extraer la memoria no es suficiente. Debemos aplicar un sello criptográfico (Hash) en el lugar de los hechos. Si este hash cambia en el futuro, significa que la evidencia fue alterada y perderá toda validez legal en un juicio.

```
cd /mnt/pendrive_forense/
sudo sh -c "sha256sum CASO_003_RAM.raw > CASO_003_RAM_hash.txt"
```

Desglose técnico de los comandos:

- `cd /mnt/pendrive_forense/`: Entramos a la carpeta para usar "rutas relativas" (solo el nombre del archivo). Esto evita que el archivo .txt guarde rutas largas que luego darán error al verificarlo en otro equipo.
- `sudo sh -c "..."`: Esto es un truco avanzado de bash. La redirección > normalmente se ejecuta con los permisos del usuario sin privilegios. Al envolver todo el comando en `sh -c`, forzamos a que tanto la lectura (el hash) como la escritura (el archivo txt) se hagan como administrador absoluto.
- `sha256sum`: Algoritmo criptográfico de 256 bits, estándar forense actual (reemplazando al antiguo MD5 por ser más seguro contra colisiones).

Paso 4: Aislamiento de la Escena

Explicación para la clase: Con la evidencia volátil asegurada, ahora sí procedemos a aislar el equipo para proteger el almacenamiento físico de ransomware u otras alteraciones remotas.

```
cd ~  
sudo umount /mnt/pendrive_forense  
sudo poweroff
```

Desglose técnico de los comandos:

- `cd ~`: Salimos de la carpeta del pendrive para volver a nuestro directorio base. *Concepto:* En Linux, si intentas desmontar un disco mientras tu consola está posicionada dentro de él, el sistema te devolverá el error `device is busy` (dispositivo ocupado) para proteger los datos.
- `umount`: Desconecta lógicamente el pendrive del sistema operativo, asegurando que todos los datos pendientes en la caché se escriban físicamente en el USB.
- `poweroff`: Apaga el equipo abruptamente. *Concepto:* El "Pull the plug" detiene cualquier proceso de cifrado o borrado malicioso que estuviera ocurriendo.

FASE 2: Análisis en el Laboratorio (Búsqueda de Malware Avanzado)

Entorno: Máquina Virtual Centrx (Laboratorio Forense)

Objetivo: Interpretar estructuras de memoria de Windows XP infectadas por el Troyano Bancario "Cridex".

Paso 1: Adquisición de la Muestra

```
mkdir -p ~/Escritorio/CASO_BANCO  
cd ~/Escritorio/CASO_BANCO  
wget -U "Mozilla/5.0 (Windows NT 10.0; Win64; x64)"  
http://files.sempersecurus.org/dumps/cridex_memdump.zip -O cridex.zip  
unzip cridex.zip
```

Explicación : Utilizamos el flag `-U` en `wget` para suplantar la identidad de nuestro navegador (User-Agent Spoofing). Muchos servidores bloquean herramientas automatizadas por seguridad (devolviendo Error 403 Forbidden). Al "disfrazarnos" de un navegador web normal de Windows, logramos sortear la restricción perimetral y descargar la evidencia.

Paso 2: Preparación de Volatility 2

El volcado cridex.vmem pertenece a una máquina con Windows XP. Esta es la razón por la que usamos **Volatility 2** y no Volatility 3. Volatility 3 dejó de dar soporte a la arquitectura de memoria tan antigua de XP. Un perito forense debe adaptarse a la época del sistema operativo que investiga.

```
cd ~/tools
wget
[https://downloads.volatilityfoundation.org/releases/2.6/volatility_2.6_lin64_standalone.zip](http
s://downloads.volatilityfoundation.org/releases/2.6/volatility_2.6_lin64_standalone.zip)
unzip volatility_2.6_lin64_standalone.zip
chmod +x volatility_2.6_lin64_standalone/volatility_2.6_lin64_standalone
```

Paso 3: Análisis Forense Paso a Paso

Nota: Para todos los comandos de Volatility 2, es obligatorio especificar el "Profile" (el mapa del sistema operativo). Para este caso, usaremos --profile=WinXPSP2x86.

A. Evaluación del Entorno (pslist)

```
./volatility_2.6_lin64_standalone -f ~/Escritorio/CASO_BANCO/cridex.vmem
--profile=WinXPSP2x86 pslist
```

Explicación de la herramienta: pslist (Process List) recorre una estructura del kernel de Windows llamada *EPROCESS*. Nos lista todos los procesos que el sistema operativo consideraba activos y legítimos.

Análisis del Output (Qué debe ver el alumno):

- Veremos columnas críticas: Name (Nombre del ejecutable), PID (Identificador del Proceso), y PPID (PID del proceso Padre, quien lo ejecutó).
- **El Engaño:** A simple vista, no hay nada llamado "virus.exe" o "hacker_tool.exe".
- **Foco en la Evidencia:** Pidan a los alumnos que anoten dos PIDs que parecen inofensivos: **PID 1484 (explorer.exe)** y **PID 1640 (reader_sl.exe)**. El primero es el escritorio de Windows, el segundo es un proceso de Adobe Reader. El atacante parece invisible.

B. connscan

```
.volatility_2.6_lin64_standalone -f ~/Escritorio/CASO_BANCO/cridex.vmem  
--profile=WinXPSP2x86 connscan
```

Explicación de la herramienta: En Windows XP, no existía el registro de conexiones detallado de sistemas modernos. connscan realiza una búsqueda heurística por toda la memoria buscando estructuras de sockets TCP (conexiones de red) que estén activas o que hayan sido cerradas recientemente.

Análisis del Output (El Descubrimiento):

- Veremos las columnas Local Address, Remote Address y Pid.
- **El Hallazgo Crítico:** Veremos que el **PID 1484 (explorer.exe)** tiene conexiones establecidas hacia direcciones IPs extrañas (41.168.5.140 y 125.19.103.198) a través del **puerto 8080**.
- **Conclusión Pericial:** El explorador de archivos de Windows *no tiene* capacidad ni razón legítima para establecer conexiones salientes hacia servidores web en puertos alternativos. Esto confirma que el proceso ha sido secuestrado y está funcionando como puente de comunicación con el atacante (C2 - Command & Control).

C. Encontrando el Código Inyectado (malfind)

```
.volatility_2.6_lin64_standalone -f ~/Escritorio/CASO_BANCO/cridex.vmem  
--profile=WinXPSP2x86 malfind
```

Explicación de la herramienta: Un atacante profesional no deja su malware en el disco duro porque el antivirus lo detectaría al instante. Utiliza técnicas de "Process Hollowing" o "DLL Injection". malfind (Malware Find) escanea los VADs (Virtual Address Descriptors) de cada proceso en la memoria.

Busca específicamente bloques de memoria que tengan permisos

PAGE_EXECUTE_READWRITE (Ejecutar, Leer y Escribir). Por seguridad, los sistemas operativos modernos casi nunca asignan estos tres permisos a la vez de forma legítima, ya que es el caldo de cultivo ideal para el código malicioso.

Análisis del Output (La Prueba Irrefutable):

- La consola mostrará volcados hexadecimales (Hexdump) pertenecientes al explorer.exe (PID 1484) y al reader_sl.exe (PID 1640).
- **La Firma:** Pidan a los alumnos que miren la primera línea del bloque hexadecimal. Verán los valores **4d 5a**, y en su traducción ASCII a la derecha, las letras **MZ**.
- **Conclusión Pericial:** MZ son las iniciales de Mark Zbikowski, el arquitecto de Microsoft que diseñó el formato de todos los archivos ejecutables (.exe y .dll) en Windows (Formato PE - Portable Executable).
- **El Cierre:** Encontrar la firma MZ (un ejecutable completo) flotando libremente dentro del espacio de memoria de Adobe Reader o de Explorer, con permisos de ejecución y escritura, es la prueba judicial irrefutable de que un troyano fue inyectado de forma furtiva en la memoria RAM de la víctima. El caso está resuelto.